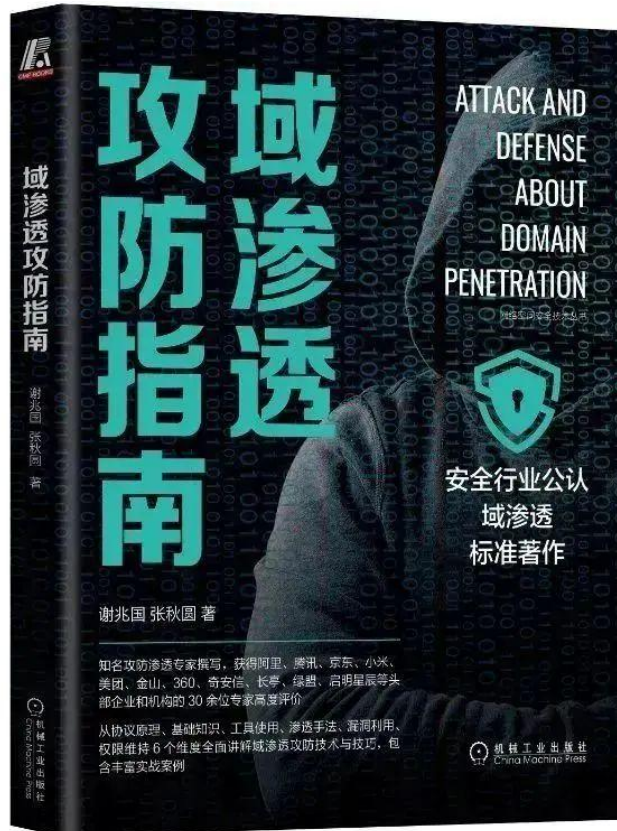


ldapsearch 的使用

本文部分节选于《域渗透攻防指南》，购买请长按如下图片扫码



小谢1997521 为你推荐

【限量签名版】《域渗透攻防指南》

¥99 ¥129



本商品由 放心购 提供保障

谢公子学安全

ldapsearch 是类 unix 下一款用于活动目录信息查询的工具，Kali 中自带 ldapsearch。以下演示在 Kali 系统下通过 ldapsearch 这款工具对活动目录数据进行查询。

参数

执行如下命令即可查看 ldapsearch 的一些参数：

ldapsearch -h

如图所示，查询 ldapsearch 的一些参数。

```
root@kali:~# ldapsearch -h
ldapsearch: option requires an argument -- 'h'
ldapsearch: unrecognized option -h
usage: ldapsearch [options] [filter [attributes...]]
where:
  filter          RFC 4515 compliant LDAP search filter
  attributes      whitespace-separated list of attribute descriptions
                   which may include:
                   1.1  no attributes
                   *    all user attributes
                   +    all operational attributes
Search options:
-a deref         one of never (default), always, search, or find
-A              retrieve attribute names only (no values)
-b basedn       base dn for search
-c              continuous operation mode (do not stop on errors)
-E [!]<ext>[=<extparam>] search extensions (! indicates criticality)
                  [!]domainScope          (domain scope)
                  !dontUseCopy             (Don't Use Copy)
                  [!]mv=<filter>           (RFC 3876 matched values filter)
                  [!]pr=<size>[/prompt|noprompt] (RFC 2696 paged results/prompt)
                  [!]sss=[-]<attr[:OID]>[/[-]<attr[:OID]>...]]
                                          (RFC 2891 server side sorting)
                  [!]subentries[=true|false] (RFC 3672 subentries)
                  [!]sync=ro[/<cookie>]     (RFC 4533 LDAP Sync refreshOnly)
                                          rp[/<cookie>[/<slimit>] (refreshAndPersist)
                  [!]vlv=<before>/<after>/<offset>/<count>|:<value>)
                                          (ldapv3-vlv-09 virtual list views)
                  [!]deref=derefAttr:attr[,...][;derefAttr:attr[,...][;...]]
```

常见的几个参数如下：

参数说明

-H ldapuri, 格式为 ldap://机器名或者 IP:端口号，不能与 -h 和 -p 同时使用

- h LDAP 服务器 IP 或者可解析的 hostname, 与 -p 可结合使用, 不能与 -H 同时使用
- p LDAP 服务器端口号, 与 -h 可结合使用, 不能与 -H 同时使用。不指定时默认为 389 端口
- x 使用简单认证方式
- D 认证的用户名
- w 密码, 与 -W 二者选一
- W 不输入密码, 会交互式的提示用户输入密码, 与 -w 二者选一
- b 指定 BaseDN 进行查询
- f 从文件中读取操作, 在 RFC 4515 中有更详细的说明
- c 出错后忽略当前错误继续执行, 缺省情况下遇到错误即终止
- n 模拟操作但并不实际执行, 用于验证, 常与 -v 一同使用进行问题定位
- v 显示详细信息
- d 显示 debug 信息, 可设定级别
- o 输出为文件
- s 指定搜索范围, 可选值: base | one | sub | children

使用

以下是在 Kali 系统环境下演示 ldapsearch 工具的使用。

1. 连接选项

下面这几个是连接选项, 也就是在连接的时候指定的参数。由于使用 ldapsearch 是在域外使用, 因此需要指定域控制器, 并且提供一个有效的域账号密码。如下:

- -H: ldapuri, 格式为 ldap://机器名或者 IP:端口号, 不能与-h 和-p 同时使用

- -h: LDAP 服务器 IP 或者可解析的 hostname, 与-p 可结合使用, 不能与-H 同时使用

- -p: LDAP 服务器端口号, 与 -h 可结合使用, 不能与-H 同时使用。不指定时默认为 389 端口

- -D: 指定用户

- -w: 指定密码

- -W: 不输入密码, 会交互式的提示用户输入密码, 与-w 二者选一

可以使用-H 参数或-h 参数指定域控, -p 参数指定端口, -D 参数指定域用户名、-w 参数或-W 参数指定密码。如下命令:

#使用 hack 账号密码-H 参数连接域控 10.211.55.4 的 389 端口

```
ldapsearch -H ldap://10.211.55.4:389 -D "hack@xie.com" -w P@ss1234
```

#使用 hack 账号密码-h 参数连接域控 10.211.55.4 -p 指定 389 端口

```
ldapsearch -h 10.211.55.4 -p 389 -D "hack@xie.com" -w P@ss1234
```

#使用 hack 账号密码-h 参数连接域控 10.211.55.4 -p 指定 389 端口, 此时不输入密码, 在交互式中输入密码

```
ldapsearch -h 10.211.55.4 -p 389 -D "hack@xie.com" -W
```

如图所示, 使用-H 参数指定域控及端口进行连接, 并且提供一个有效凭据, 凭据正确与否, 返回结果不一致。

```

root@kali:~# ldapsearch -H ldap://10.211.55.4:389 -D "hack@xie.com" -w P@ss1234
# extended LDIF
#
# LDAPv3
# base <> (default) with scope subtree
# filter: (objectclass=*)
# requesting: ALL
#
# search result
search: 2
result: 32 No such object
text: 0000208D: NameErr: DSID-03100213, problem 2001 (NO_OBJECT), data 0, best
match of:
    ''

# numResponses: 1
root@kali:~# ldapsearch -H ldap://10.211.55.4:389 -D "hack@xie.com" -w P@ss123
ldap_bind: Invalid credentials (49)
additional info: 80090308: LdapErr: DSID-0C0903C5, comment: AcceptSecurityContext error, data 52e, v2580

```

如图所示，使用-h 参数指定域控，使用-p 参数指定端口进行连接，并且提供一个有效凭据，凭据正确与否，返回结果不一致。

```

root@kali:~# ldapsearch -h 10.211.55.4 -p 389 -D "hack@xie.com" -w P@ss1234
# extended LDIF
#
# LDAPv3
# base <> (default) with scope subtree
# filter: (objectclass=*)
# requesting: ALL
#
# search result
search: 2
result: 32 No such object
text: 0000208D: NameErr: DSID-03100213, problem 2001 (NO_OBJECT), data 0, best
match of:
    ''

# numResponses: 1
root@kali:~# ldapsearch -h 10.211.55.4 -p 389 -D "hack@xie.com" -w P@ss123
ldap_bind: Invalid credentials (49)
additional info: 80090308: LdapErr: DSID-0C0903C5, comment: AcceptSecurityContext error, data 52e, v2580

```

如图所示，使用-h 参数指定域控，使用-p 参数指定端口进行连接，回车后交互式输入密码。

```
root@kali:~# ldapsearch -h 10.211.55.4 -p 389 -D "hack@xie.com" -W
Enter LDAP Password:
# extended LDIF
#
# LDAPv3
# base <> (default) with scope subtree
# filter: (objectclass=*)
# requesting: ALL
#
# search result
search: 2
result: 32 No such object
text: 0000208D: NameErr: DSID-03100213, problem 2001 (NO_OBJECT), data 0, best
match of:
    ''
# numResponses: 1
```

2. 过滤选项

下面这个是过滤参数，也就是进行查询的时候需要过滤的一些条件：

- -b：指定要查询的根节点 basedn，以及过滤的语法

例如如下命令：

#查找指定 basedn 的信息

```
ldapsearch -h 10.211.55.4 -p 389 -D "hack@xie.com" -w P@ss1234 -b "CN=Administrator,CN=Users,DC=xie,DC=com"
```

#查找指定 basedn 的信息,并且过滤出 name=administrator 的条目

```
ldapsearch -h 10.211.55.4 -p 389 -D "hack@xie.com" -w P@ss1234 -b "CN=Users,DC=xie,DC=com" "name=administrator"
```

如图所示，查找指定的 basedn 的信息，也就是查找 administrator 的信息。


```

root@kali:~# ldapsearch -h 10.211.55.4 -p 389 -D "hack@xie.com" -w P@ss1234 -b "CN=Administrator,CN=Users,DC=xie,DC=com"
# extended LDIF
#
# LDAPv3
# base <CN=Administrator,CN=Users,DC=xie,DC=com> with scope subtree
# filter: (objectclass=*)
# requesting: ALL
#
# Administrator, Users, xie.com
dn: CN=Administrator,CN=Users,DC=xie,DC=com
objectClass: top
objectClass: person
objectClass: organizationalPerson
objectClass: user
cn: Administrator
description:: 566h55CG6K6h566X5py6K0WfnynmoTlhoXnva7luJDmILc=
distinguishedName: CN=Administrator,CN=Users,DC=xie,DC=com
instanceType: 4
whenCreated: 20210227123929.0Z
whenChanged: 20220128150755.0Z
displayName: Administrator
uSNCreated: 8196
memberOf: CN=Organization Management,OU=Microsoft Exchange Security Groups,DC=
xie,DC=com
memberOf: CN=Group Policy Creator Owners,CN=Users,DC=xie,DC=com
memberOf: CN=Domain Admins,CN=Users,DC=xie,DC=com
memberOf: CN=Enterprise Admins,CN=Users,DC=xie,DC=com
memberOf: CN=Schema Admins,CN=Users,DC=xie,DC=com
memberOf: CN=Administrators,CN=Builtin,DC=xie,DC=com
uSNChanged: 54415
proxyAddresses: SMTP:Administrator@xie.com
name: Administrator

```

如图所示，查找指定的 basedn 的信息,并且过滤出 name=administrator 的条目。可以看到和好上面搜索的结果一样。

```

root@kali:~# ldapsearch -h 10.211.55.4 -p 389 -D "hack@xie.com" -w P@ss1234 -b "CN=Users,DC=xie,DC=com" "name=administrator"
# extended LDIF
#
# LDAPv3
# base <CN=Users,DC=xie,DC=com> with scope subtree
# filter: name=administrator
# requesting: ALL
#
# Administrator, Users, xie.com
dn: CN=Administrator,CN=Users,DC=xie,DC=com
objectClass: top
objectClass: person
objectClass: organizationalPerson
objectClass: user
cn: Administrator
description:: 566h55CG6K6h566X5py6K0WfnynmoTlhoXnva7luJDmILc=
distinguishedName: CN=Administrator,CN=Users,DC=xie,DC=com
instanceType: 4
whenCreated: 20210227123929.0Z
whenChanged: 20220128150755.0Z
displayName: Administrator
uSNCreated: 8196
memberOf: CN=Organization Management,OU=Microsoft Exchange Security Groups,DC=
xie,DC=com
memberOf: CN=Group Policy Creator Owners,CN=Users,DC=xie,DC=com
memberOf: CN=Domain Admins,CN=Users,DC=xie,DC=com
memberOf: CN=Enterprise Admins,CN=Users,DC=xie,DC=com
memberOf: CN=Schema Admins,CN=Users,DC=xie,DC=com
memberOf: CN=Administrators,CN=Builtin,DC=xie,DC=com
uSNChanged: 54415
proxyAddresses: SMTP:Administrator@xie.com
name: Administrator

```

3. 显示选项

默认情况下，查找的结果会显示对象的所有属性，如果想只显示指定属性的话，在末尾加上属性名即可。也可以使用-o 参数将结果导出在文件中。如下命令：

#查找指定 administrator 用户的所有信息

```
ldapsearch -h 10.211.55.4 -p 389 -D "hack@xie.com" -w P@ss1234 -b "CN=Administrator,CN=Users,DC=xie,DC=com"
```

#查找指定 administrator 用户的 dn 属性

```
ldapsearch -h 10.211.55.4 -p 389 -D "hack@xie.com" -w P@ss1234 -b "CN=Administrator,CN=Users,DC=xie,DC=com" dn
```

#查找指定 administrator 用户的 dn 属性，使用 grep 过滤，结果更直观

```
ldapsearch -h 10.211.55.4 -p 389 -D "hack@xie.com" -w P@ss1234 -b "CN=Administrator,CN=Users,DC=xie,DC=com" | grep dn
```

#查找指定 administrator 用户的所有信息，并将结果导出在指定 LDIF 格式文件中

```
ldapsearch -h 10.211.55.4 -p 389 -D "hack@xie.com" -w P@ss1234 -b "CN=Administrator,CN=Users,DC=xie,DC=com" -o ldif-wrap=no > administrator.ldif
```

#接着使用 adoffline.py 脚本将 LDIF 格式文件转换为 sqlite 格式文件

```
python adoffline.py administrator.ldif
```

如图所示，查询指定 administrator 用户的所有信息。


```

root@kali:~# ldapsearch -h 10.211.55.4 -p 389 -D "hack@xie.com" -w P@ss1234 -b "CN=Administrator,CN=Users,DC=xie,DC=com"
# extended LDIF
#
# LDAPv3
# base <CN=Administrator,CN=Users,DC=xie,DC=com> with scope subtree
# filter: (objectclass=*)
# requesting: ALL
#
# Administrator, Users, xie.com
dn: CN=Administrator,CN=Users,DC=xie,DC=com
objectClass: top
objectClass: person
objectClass: organizationalPerson
objectClass: user
cn: Administrator
description: 566h55CG6K6h566X5py6K0WfnynnmoTlhoXnva7luJDmILc=
distinguishedName: CN=Administrator,CN=Users,DC=xie,DC=com
instanceType: 4
whenCreated: 20210227123929.0Z
whenChanged: 20220128150755.0Z
displayName: Administrator
uSNCreated: 8196
memberOf: CN=Organization Management,OU=Microsoft Exchange Security Groups,DC=xie,DC=com
memberOf: CN=Group Policy Creator Owners,CN=Users,DC=xie,DC=com
memberOf: CN=Domain Admins,CN=Users,DC=xie,DC=com
memberOf: CN=Enterprise Admins,CN=Users,DC=xie,DC=com
memberOf: CN=Schema Admins,CN=Users,DC=xie,DC=com
memberOf: CN=Administrators,CN=Builtin,DC=xie,DC=com
uSNChanged: 54415
proxyAddresses: SMTP:Administrator@xie.com
name: Administrator
objectGUID:: Bb0rWcNHUqKJLl0evZ4pA==

```

如图所示，查询指定 administrator 用户的 dn 属性。可以看到即使这样，查询出的结果还不是很直观。

```

root@kali:~# ldapsearch -h 10.211.55.4 -p 389 -D "hack@xie.com" -w P@ss1234 -b "CN=Administrator,CN=Users,DC=xie,DC=com" dn
# extended LDIF
#
# LDAPv3
# base <CN=Administrator,CN=Users,DC=xie,DC=com> with scope subtree
# filter: (objectclass=*)
# requesting: dn
#
# Administrator, Users, xie.com
dn: CN=Administrator,CN=Users,DC=xie,DC=com

# search result
search: 2
result: 0 Success

# numResponses: 2
# numEntries: 1

```

因此我们可以使用 grep 来过滤输出结果，只显示 dn。如图 3-95 所示，使用 grep 过滤结果中的 dn，结果很直观

```

root@kali:~# ldapsearch -h 10.211.55.4 -p 389 -D "hack@xie.com" -w P@ss1234 -b "CN=Administrator,CN=Users,DC=xie,DC=com" | grep dn
dn: CN=Administrator,CN=Users,DC=xie,DC=com

```

如图所示，查询指定 administrator 用户的所有信息，并导出成 LDIF 格式的 administrator.ldif 文件，接着使用 adoffline.py 将其转为 sqlite 格式文件。可以看到最后生成/tmp/tmpOWK1Tm.20210929183345.ad-ldap.db 文件。

```

root@kali:~# ldapsearch -h 10.211.55.4 -p 389 -D "hack@xie.com" -w Pëss1234 -b "CN=Administrator,CN=Users,DC=xie,DC=com" -o ldif-w
rap=no > administrator.ldif
root@kali:~# ls -lh | grep administrator.ldif
-rw-r--r-- 1 root root 4.5K 9月 29 18:33 administrator.ldif
root@kali:~# python adoffline.py administrator.ldif

.mMMMMMm.      MmM  M  WW  W  WW  RRRRR
mMMMMMMMMMMMM. MM  MM  W  W  W  R  R
/MMMM- -MM.    MM  MM  W  W  W  R  R
/MMM.  _  \  ^  M  M  M  W  W  W  RRRR
IM.   aRRr  /W  M  M  M  W  W  W  R  R
\  .. ^^^  wWWW  M  M  M  W  W  R  R
/WW\.. .wWWW/    M  M  M  W  W  R  R
|WWWWWWWWWW/
.WWWWW.

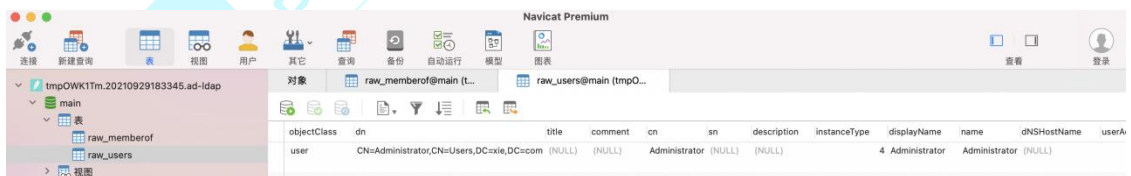
ADOffline - Convert AD LDAP to SQL
stuart.morgan@mwrinfosecurity.com | @ukstufus

[29/Sep/21 18:33:45] Creating database: /tmp/tmpOWK1Tm.20210929183345.ad-ldap.db
[29/Sep/21 18:33:45] Reading LDIF...done
[29/Sep/21 18:33:45] Parsing LDIF...
  Reading line 96/96 (100%)
[29/Sep/21 18:33:45] Calculating user chain of ancestry (nested groups)...
  Processed DN 1/1 (100%)
[29/Sep/21 18:33:45] Completed
[29/Sep/21 18:33:45] Calculating computer chain of ancestry (nested groups)...

Users: 1
Groups: 0
Computers: 0
Associations: 0

```

最后便可以使用 navicat 打开 sqlite 格式文件了。如图所示，使用 navicat 打开 tmpOWK1Tm.20210929183345.ad-ldap.db 文件，可以很直观的看到 administrator 用户的一些属性信息。



The screenshot shows the Navicat Premium interface. On the left, the database structure is expanded, showing 'main' > 'raw_memberof' > 'raw_users'. The main window displays a table with the following data:

objectClass	dn	title	comment	cn	sn	description	instanceType	displayName	name	dNSHostName	userA
user	CN=Administrator,CN=Users,DC=xie,DC=com	(NULL)	(NULL)	Administrator	(NULL)	(NULL)	4	Administrator	Administrator	(NULL)	

查询示例

以下演示一些在实战中经常用到的一些查询语法。

1. 机器相关

下面这几个是与机器相关的查询命令。

(1) 查询域中所有域控

以下命令是查询域中所有的域控。

```
ldapsearch -h 10.211.55.4 -p 389 -D "hack@xie.com" -w P@ss1234 -b "OU=Domain Controllers,DC=xie,DC=com" "objectcategory=computer" | grep dn
```

如图所示，查询到了域内所有的域控。

```
root@kali:~# ldapsearch -h 10.211.55.4 -p 389 -D "hack@xie.com" -w P@ss1234 -b "OU=Domain Controllers,DC=xie,DC=com" "objectcategory=computer" | grep dn
dn: CN=AD01,OU=Domain Controllers,DC=xie,DC=com
```

(2) 查询域中所有机器

以下命令是查询域中所有的机器，包括域控。

```
ldapsearch -h 10.211.55.4 -p 389 -D "hack@xie.com" -w P@ss1234 -b "DC=xie,DC=com" "objectcategory=computer" | grep dn
```

如图所示，查询到了域内所有的机器，包括域控 AD01。

```
root@kali:~# ldapsearch -h 10.211.55.4 -p 389 -D "hack@xie.com" -w P@ss1234 -b "DC=xie,DC=com" "objectcategory=computer" | grep dn
dn: CN=AD01,OU=Domain Controllers,DC=xie,DC=com
dn: CN=MAIL,CN=Computers,DC=xie,DC=com
dn: CN=WIN10,CN=Computers,DC=xie,DC=com
dn: CN=WIN7,CN=Computers,DC=xie,DC=com
```

(3) 查询指定机器详细信息

以下命令是查询域中机器的详细信息。

```
ldapsearch -h 10.211.55.4 -p 389 -D "hack@xie.com" -w P@ss1234 -b "DC=xie,DC=com" "(&(objectcategory=computer)(name=mail))"
```

如图所示，查询指定 mail 机器的详细信息。

```

root@kali:~# ldapsearch -h 10.211.55.4 -p 389 -D "hack@xie.com" -w P@ss1234 -b "DC=xie,DC=com" "(&(objectcategory=computer)(name=mail))"
# extended LDIF
#
# LDAPv3
# base <DC=xie,DC=com> with scope subtree
# filter: (&(objectcategory=computer)(name=mail))
# requesting: ALL
#
# MAIL, Computers, xie.com
dn: CN=MAIL,CN=Computers,DC=xie,DC=com
objectClass: top
objectClass: person
objectClass: organizationalPerson
objectClass: user
objectClass: computer
cn: MAIL
distinguishedName: CN=MAIL,CN=Computers,DC=xie,DC=com
instanceType: 4
whenCreated: 20210307080618.0Z
whenChanged: 20220128111148.0Z
uSNCreated: 20499
memberOf: CN=Exchange Install Domain Servers,CN=Microsoft Exchange System Objects,DC=xie,DC=com
memberOf: CN=Managed Availability Servers,OU=Microsoft Exchange Security Groups,DC=xie,DC=com
memberOf: CN=Exchange Trusted Subsystem,OU=Microsoft Exchange Security Groups,DC=xie,DC=com
memberOf: CN=Exchange Servers,OU=Microsoft Exchange Security Groups,DC=xie,DC=com
uSNChanged: 53991
name: MAIL
objectGUID:: eToBx+CK7E6N9iJlkPNq4A==

```

2. 用户相关

下面这几个是与用户相关的查询命令。

(1) 查询域管理员

以下命令是查询域管理员组中含有哪些用户。

```

ldapsearch -h 10.211.55.4 -p 389 -D "hack@xie.com" -w P@ss1234 -b "CN=Domain Admins,CN=Users,DC=xie,DC=com" | grep member

```

如图所示，可以看到查询到域管理员组中有 admin 和 administrator 两个用户。

```

root@kali:~# ldapsearch -h 10.211.55.4 -p 389 -D "hack@xie.com" -w P@ss1234 -b "CN=Domain Admins,CN=Users,DC=xie,DC=com" member
# extended LDIF
#
# LDAPv3
# base <CN=Domain Admins,CN=Users,DC=xie,DC=com> with scope subtree
# filter: (objectclass=*)
# requesting: member
#
# Domain Admins, Users, xie.com
dn: CN=Domain Admins,CN=Users,DC=xie,DC=com
member: CN=admin,CN=Users,DC=xie,DC=com
member: CN=Administrator,CN=Users,DC=xie,DC=com

# search result
search: 2
result: 0 Success

# numResponses: 2
# numEntries: 1

```

(2) 查询域内所有用户

以下命令是查询域内所有用户。

```

ldapsearch -h 10.211.55.4 -p 389 -D "hack@xie.com" -w P@ss1234 -b "DC=xie,DC=com" "(&(objectCategory=person)(objectClass=user))" | grep dn

```

如图所示，可以看到查询到域内的所有用户。

```

root@kali:~# ldapsearch -h 10.211.55.4 -p 389 -D "hack@xie.com" -w P@ss1234 -b "DC=xie,DC=com" "(&(objectCategory=person)(objectClass=user))" | grep dn
dn: CN=Administrator,CN=Users,DC=xie,DC=com
dn: CN=Guest,CN=Users,DC=xie,DC=com
dn: CN=krbtgt,CN=Users,DC=xie,DC=com
dn: CN=Exchange Online-ApplicationAccount,CN=Users,DC=xie,DC=com
dn: CN=SystemMailbox{1f05a927-617d-4362-be07-8a7175347545},CN=Users,DC=xie,DC=com
dn: CN=SystemMailbox{bb558c35-97f1-4cb9-8ff7-d53741dc928c},CN=Users,DC=xie,DC=com
dn: CN=SystemMailbox{e0dc1c29-89c3-4034-b678-e6c29d823ed9},CN=Users,DC=xie,DC=com
dn: CN=DiscoverySearchMailbox {D919BA05-46A6-415F-80AD-7E09334BB852},CN=Users,DC=xie,DC=com
dn: CN=Migration.8f3e7716-2011-43e4-96b1-aba62d229136,CN=Users,DC=xie,DC=com
dn: CN=FederatedEmail.4c1f4d8b-8179-4148-93bf-00a95fae042,CN=Users,DC=xie,DC=com
dn: CN=SystemMailbox{8cc370d3-822a-4ab8-a926-bb94bd0641a9},CN=Users,DC=xie,DC=com
dn: CN=HealthMailboxa20a8789a5ed452f8a13bb8f825a26bc,CN=Monitoring Mailboxes,CN=Users,DC=xie,DC=com
dn: CN=HealthMailbox66b93d1708fd4e5d89164c7a2c295aff,CN=Monitoring Mailboxes,CN=Users,DC=xie,DC=com
dn: CN=HealthMailbox99523f51f7dc44b19b2aff9e1f742916,CN=Monitoring Mailboxes,CN=Users,DC=xie,DC=com
dn: CN=HealthMailbox7e99ca4c80414ff39e0d804efc16cbbd,CN=Monitoring Mailboxes,CN=Users,DC=xie,DC=com
dn: CN=HealthMailbox619a0417337f48ddb8ec9c9c5abcf9a,CN=Monitoring Mailboxes,CN=Users,DC=xie,DC=com
dn: CN=HealthMailboxff45b942bb4f417195c2840bdc65c48e,CN=Monitoring Mailboxes,CN=Users,DC=xie,DC=com
dn: CN=HealthMailbox5ebb96761ba45efaf9aef7dd176cf6a,CN=Monitoring Mailboxes,CN=Users,DC=xie,DC=com
dn: CN=HealthMailboxSeba7b043c3f42f285634b70e9d26952,CN=Monitoring Mailboxes,CN=Users,DC=xie,DC=com
dn: CN=HealthMailbox7a7183d6b31e4d668d5050402be58552,CN=Monitoring Mailboxes,CN=Users,DC=xie,DC=com
dn: CN=HealthMailboxfea56fbcdc444bc2b431c6e966626103,CN=Monitoring Mailboxes,CN=Users,DC=xie,DC=com
dn: CN=HealthMailbox66622de54c3f488ca9d75aeeed7d79cb,CN=Monitoring Mailboxes,CN=Users,DC=xie,DC=com
dn: CN=test,CN=Users,DC=xie,DC=com
dn: CN=hack,CN=Users,DC=xie,DC=com
dn: CN=admin,CN=Users,DC=xie,DC=com

```

(3) 查询指定域用户

以下命令是查询域内指定用户 test。


```
ldapsearch -h 10.211.55.4 -p 389 -D "hack@xie.com" -w P@ss1234 -b "DC=xi
e,DC=com" "(&(objectCategory=person)(objectClass=user)(name=test))"
```

如图所示，可以看到查询到域内指定用户 test 的信息。

```
root@kali:~# ldapsearch -h 10.211.55.4 -p 389 -D "hack@xie.com" -w P@ss1234 -b "DC=xie,DC=com" "(&(objectCategory=person)(objectCl
ass=user)(name=test))"
# extended LDIF
#
# LDAPv3
# base <DC=xie,DC=com> with scope subtree
# filter: (&(objectCategory=person)(objectClass=user)(name=test))
# requesting: ALL
#
# test, Users, xie.com
dn: CN=test,CN=Users,DC=xie,DC=com
objectClass: top
objectClass: person
objectClass: organizationalPerson
objectClass: user
cn: test
distinguishedName: CN=test,CN=Users,DC=xie,DC=com
instanceType: 4
whenCreated: 20210307103928.0Z
whenChanged: 20220128111124.0Z
displayName: test
uSNCreated: 36773
uSNChanged: 53972
proxyAddresses: SMTP:test@xie.com
name: test
objectGUID:: yJpmi850UyRQqF/7v90pg==
userAccountControl: 512
badPwdCount: 0
codePage: 0
countryCode: 0
badPasswordTime: 0
lastLogoff: 0
lastLogon: 132878418844313135
```

(4) 查询指定域用户的 sid

以下命令是查询域内指定 test 用户的 sid 值。

```
ldapsearch -h 10.211.55.4 -p 389 -D "hack@xie.com" -w P@ss1234 -b "DC=xi
e,DC=com" "(&(objectCategory=person)(objectClass=user)(name=test))" |grep objec
tsid
```

如图所示，可以看到查询出指定 test 用户的 sid 值。

```
root@kali:~# ldapsearch -h 10.211.55.4 -p 389 -D "hack@xie.com" -w P@ss1234 -b "DC=xie,DC=com" "(&(objectCategory=person)(objectCl
ass=user)(name=test))" | grep objectSid
objectSid:: AQuAAAAAAAAUVAAPLxRTpnTA9h3ZbnxegQAAA==
```

(5) 查询指定 sid 对应的用户

以下命令是查询域内指定 sid 值对应的用户。


```
ldapsearch -h 10.211.55.4 -p 389 -D "hack@xie.com" -w P@ss1234 -b "DC=xie,DC=com" "(&(objectCategory=person)(objectClass=user)(objectSid=S-1-5-21-1313979556-3624129433-4055459191-1146))" |grep dn
```

如图所示，可以看到查询出指定 sid 值对应的用户为 test。

```
root@kali:~# ldapsearch -h 10.211.55.4 -p 389 -D "hack@xie.com" -w P@ss1234 -b "DC=xie,DC=com" "(&(objectCategory=person)(objectClass=user)(objectSid=S-1-5-21-1313979556-3624129433-4055459191-1146))" |grep dn
dn: CN=test,CN=Users,DC=xie,DC=com
```

(6) 查询指定域用户属于哪些组

以下命令是查询指定域用户 administrator 属于哪些组。

```
ldapsearch -h 10.211.55.4 -p 389 -D "hack@xie.com" -w P@ss1234 -b "DC=xie,DC=com" "(&(objectCategory=person)(objectClass=user)(name=administrator))" |grep memberOf
```

如图所示，可以看到查询出指定 administrator 用户的所属组。

```
root@kali:~# ldapsearch -h 10.211.55.4 -p 389 -D "hack@xie.com" -w P@ss1234 -b "DC=xie,DC=com" "(&(objectCategory=person)(objectClass=user)(name=administrator))" |grep memberOf
memberOf: CN=Organization Management,OU=Microsoft Exchange Security Groups,DC=xie,DC=com
memberOf: CN=Group Policy Creator Owners,CN=Users,DC=xie,DC=com
memberOf: CN=Domain Admins,CN=Users,DC=xie,DC=com
memberOf: CN=Enterprise Admins,CN=Users,DC=xie,DC=com
memberOf: CN=Schema Admins,CN=Users,DC=xie,DC=com
memberOf: CN=Administrators,CN=Builtin,DC=xie,DC=com
```

(7) 查询域内开启“Do not require Kerberos preauthentication”选项的用户

如下命令是查询域内开启了不需要域认证的用户。

```
ldapsearch -h 10.211.55.4 -p 389 -D "hack@xie.com" -w P@ss1234 -b "DC=xie,DC=com" "useraccountcontrol:1.2.840.113556.1.4.803:=4194304" |grep dn
```

如图所示，可以看到查询到 hack 用户开启了不需要域认证。

```
root@kali:~# ldapsearch -h 10.211.55.4 -p 389 -D "hack@xie.com" -w P@ss1234 -b "DC=xie,DC=com" "useraccountcontrol:1.2.840.113556.1.4.803:=4194304" |grep dn
dn: CN=hack,CN=Users,DC=xie,DC=com
```

(8) 查询受保护的用户

如下命令是查询域内受保护的用户。

```
ldapsearch -h 10.211.55.4 -p 389 -D "hack@xie.com" -w P@ss1234 -b "DC=xie,DC=com" "(&(objectcategory=person)(samaccountname=*)(admincount=1))" |grep dn
```

如图所示，查询到四个用户在域内受保护。

```
root@kali:~# ldapsearch -h 10.211.55.4 -p 389 -D "hack@xie.com" -w P@ss1234 -b "DC=xie,DC=com" "(&(objectcategory=person)(samaccountname=*)(admincount=1))" |grep dn
dn: CN=Administrator,CN=Users,DC=xie,DC=com
dn: CN=krbtgt,CN=Users,DC=xie,DC=com
dn: CN=test,CN=Users,DC=xie,DC=com
dn: CN=admin,CN=Users,DC=xie,DC=com
```

3. 组相关

下面这几个是与组相关的查询命令。

(1) 查询域内所有的全局组

以下命令是查询域内所有的全局组。

```
ldapsearch -h 10.211.55.4 -p 389 -D "hack@xie.com" -w P@ss1234 -b "DC=xie,DC=com" "(groupype=-2147483646)" |grep dn
```

如图所示，可以看到查询出域内所有的全局组。

```
root@kali:~# ldapsearch -h 10.211.55.4 -p 389 -D "hack@xie.com" -w P@ss1234 -b "DC=xie,DC=com" "(groupype=-2147483646)" |grep dn
dn: CN=Domain Computers,CN=Users,DC=xie,DC=com
dn: CN=Domain Controllers,CN=Users,DC=xie,DC=com
dn: CN=Domain Admins,CN=Users,DC=xie,DC=com
dn: CN=Domain Users,CN=Users,DC=xie,DC=com
dn: CN=Domain Guests,CN=Users,DC=xie,DC=com
dn: CN=Group Policy Creator Owners,CN=Users,DC=xie,DC=com
dn: CN=Read-only Domain Controllers,CN=Users,DC=xie,DC=com
dn: CN=Cloneable Domain Controllers,CN=Users,DC=xie,DC=com
dn: CN=Protected Users,CN=Users,DC=xie,DC=com
dn: CN=DnsUpdateProxy,CN=Users,DC=xie,DC=com
dn: CN=Exchange Install Domain Servers,CN=Microsoft Exchange System Objects,DC=xie,DC=com
```

(2) 查询域内所有通用组

以下命令是查询域内所有的通用组。

```
ldapsearch -h 10.211.55.4 -p 389 -D "hack@xie.com" -w P@ss1234 -b "DC=xie,DC=com" "(grouptype=-2147483640)" | grep dn
```

如图所示，可以看到查询出域内所有的通用组。

```
root@kali:~# ldapsearch -h 10.211.55.4 -p 389 -D "hack@xie.com" -w P@ss1234 -b "DC=xie,DC=com" "(grouptype=-2147483640)" | grep dn
dn: CN=Schema Admins,CN=Users,DC=xie,DC=com
dn: CN=Enterprise Admins,CN=Users,DC=xie,DC=com
dn: CN=Enterprise Read-only Domain Controllers,CN=Users,DC=xie,DC=com
dn: CN=Organization Management,OU=Microsoft Exchange Security Groups,DC=xie,DC=com
dn: CN=Recipient Management,OU=Microsoft Exchange Security Groups,DC=xie,DC=com
dn: CN=View-Only Organization Management,OU=Microsoft Exchange Security Groups,DC=xie,DC=com
dn: CN=Public Folder Management,OU=Microsoft Exchange Security Groups,DC=xie,DC=com
dn: CN=UM Management,OU=Microsoft Exchange Security Groups,DC=xie,DC=com
dn: CN=Help Desk,OU=Microsoft Exchange Security Groups,DC=xie,DC=com
dn: CN=Records Management,OU=Microsoft Exchange Security Groups,DC=xie,DC=com
dn: CN=Discovery Management,OU=Microsoft Exchange Security Groups,DC=xie,DC=com
dn: CN=Server Management,OU=Microsoft Exchange Security Groups,DC=xie,DC=com
dn: CN=Delegated Setup,OU=Microsoft Exchange Security Groups,DC=xie,DC=com
dn: CN=Hygiene Management,OU=Microsoft Exchange Security Groups,DC=xie,DC=com
dn: CN=Compliance Management,OU=Microsoft Exchange Security Groups,DC=xie,DC=com
dn: CN=Exchange Servers,OU=Microsoft Exchange Security Groups,DC=xie,DC=com
dn: CN=Exchange Trusted Subsystem,OU=Microsoft Exchange Security Groups,DC=xie,DC=com
dn: CN=Managed Availability Servers,OU=Microsoft Exchange Security Groups,DC=xie,DC=com
dn: CN=Exchange Windows Permissions,OU=Microsoft Exchange Security Groups,DC=xie,DC=com
dn: CN=ExchangeLegacyInterop,OU=Microsoft Exchange Security Groups,DC=xie,DC=com
```

(3) 查询域内所有的本地域组

以下命令是查询域内所有的本地域组。

```
ldapsearch -h 10.211.55.4 -p 389 -D "hack@xie.com" -w P@ss1234 -b "DC=xie,DC=com" "(!(|(grouptype=-2147483644)(grouptype=-2147483643)))" | grep dn
```

如图所示，可以看到查询出域内所有的本地域组。



```

root@kali:~# ldapsearch -h 10.211.55.4 -p 389 -D "hack@xie.com" -w P@ss1234 -b "DC=xie,DC=com" "(!(grouptype=-2147483644)(grouptyp
e=-2147483643))" | grep dn
dn: CN=Administrators,CN=Builtin,DC=xie,DC=com
dn: CN=Users,CN=Builtin,DC=xie,DC=com
dn: CN=Guests,CN=Builtin,DC=xie,DC=com
dn: CN=Print Operators,CN=Builtin,DC=xie,DC=com
dn: CN=Backup Operators,CN=Builtin,DC=xie,DC=com
dn: CN=Replicator,CN=Builtin,DC=xie,DC=com
dn: CN=Remote Desktop Users,CN=Builtin,DC=xie,DC=com
dn: CN=Network Configuration Operators,CN=Builtin,DC=xie,DC=com
dn: CN=Performance Monitor Users,CN=Builtin,DC=xie,DC=com
dn: CN=Performance Log Users,CN=Builtin,DC=xie,DC=com
dn: CN=Distributed COM Users,CN=Builtin,DC=xie,DC=com
dn: CN=IIS_IUSRS,CN=Builtin,DC=xie,DC=com
dn: CN=Cryptographic Operators,CN=Builtin,DC=xie,DC=com
dn: CN=Event Log Readers,CN=Builtin,DC=xie,DC=com
dn: CN=Certificate Service DCOM Access,CN=Builtin,DC=xie,DC=com
dn: CN=RDS Remote Access Servers,CN=Builtin,DC=xie,DC=com
dn: CN=RDS Endpoint Servers,CN=Builtin,DC=xie,DC=com
dn: CN=RDS Management Servers,CN=Builtin,DC=xie,DC=com
dn: CN=Hyper-V Administrators,CN=Builtin,DC=xie,DC=com
dn: CN=Access Control Assistance Operators,CN=Builtin,DC=xie,DC=com
dn: CN=Remote Management Users,CN=Builtin,DC=xie,DC=com
dn: CN=Server Operators,CN=Builtin,DC=xie,DC=com
dn: CN=Account Operators,CN=Builtin,DC=xie,DC=com
dn: CN=Pre-Windows 2000 Compatible Access,CN=Builtin,DC=xie,DC=com
dn: CN=Incoming Forest Trust Builders,CN=Builtin,DC=xie,DC=com
dn: CN=Windows Authorization Access Group,CN=Builtin,DC=xie,DC=com
dn: CN=Terminal Server License Servers,CN=Builtin,DC=xie,DC=com
dn: CN=WinRMRemoteWMIUsers_,CN=Users,DC=xie,DC=com
dn: CN=Cert Publishers,CN=Users,DC=xie,DC=com
dn: CN=RAS and IAS Servers,CN=Users,DC=xie,DC=com
dn: CN=Allowed RODC Password Replication Group,CN=Users,DC=xie,DC=com

```

(4) 查询指定组含有哪些对象

以下命令是查询指定组含有哪些对象。

```

ldapsearch -h 10.211.55.4 -p 389 -D "hack@xie.com" -w P@ss1234 -b "CN=Domain Admins,CN=Users,DC=xie,DC=com" member

```

如图所示，可以看到查询出域管理员组 Domain Admins 内含有 admin 和 administrator 用户。

```

root@kali:~# ldapsearch -h 10.211.55.4 -p 389 -D "hack@xie.com" -w P@ss1234 -b "CN=Domain Admins,CN=Users,DC=xie,DC=com" member
# extended LDIF
#
# LDAPv3
# base <CN=Domain Admins,CN=Users,DC=xie,DC=com> with scope subtree
# filter: (objectclass=*)
# requesting: member
#
# Domain Admins, Users, xie.com
dn: CN=Domain Admins,CN=Users,DC=xie,DC=com
member: CN=admin,CN=Users,DC=xie,DC=com
member: CN=Administrator,CN=Users,DC=xie,DC=com
# search result
search: 2
result: 0 Success
# numResponses: 2
# numEntries: 1

```

4. 委派相关

下面这几个是与委派相关的查询命令。

(1) 非约束性委派

如下命令是查询配置了非约束性委派的主机和服务帐户。

#查询域中配置非约束委派的主机

```
ldapsearch -x -H ldap://10.211.55.4:389 -D "hack@xie.com" -w P@ss1234 -b "DC=xie,DC=com" "(&(samAccountType=805306369)(userAccountControl:1.2.840.113556.1.4.803:=524288))" | grep dn
```

#查询域中配置非约束委派的服务账户

```
ldapsearch -x -H ldap://10.211.55.4:389 -D "hack@xie.com" -w P@ss1234 -b "DC=xie,DC=com" "(&(samAccountType=805306368)(userAccountControl:1.2.840.113556.1.4.803:=524288))" | grep dn
```

如图所示，可以看到查询出配置了非约束性委派的主机和服务帐户。

```
root@kali:~# ldapsearch -x -H ldap://10.211.55.4:389 -D "hack@xie.com" -w P@ss1234 -b "DC=xie,DC=com" "(&(samAccountType=805306369)(userAccountControl:1.2.840.113556.1.4.803:=524288))" | grep dn
dn: CN=AD01,OU=Domain Controllers,DC=xie,DC=com
dn: CN=AD02,OU=Domain Controllers,DC=xie,DC=com
root@kali:~# ldapsearch -x -H ldap://10.211.55.4:389 -D "hack@xie.com" -w P@ss1234 -b "DC=xie,DC=com" "(&(samAccountType=805306368)(userAccountControl:1.2.840.113556.1.4.803:=524288))" | grep dn
dn: CN=service_account,CN=Users,DC=xie,DC=com
```

(2) 查询约束性委派

如下命令是查询配置了约束性委派的主机和服务帐户。

#查询域中配置了约束性委派的主机，并可以看到被委派的 SPN

```
ldapsearch -x -H ldap://10.211.55.4:389 -D "hack@xie.com" -w P@ss1234 -b "DC=xie,DC=com" "(&(samAccountType=805306369)(msds-allowedtodelegateto=*))" | grep -e dn -e msDS-AllowedToDelegateTo
```

#查询域中配置了约束性委派的服务账户，并可以看到被委派的 SPN

```
ldapsearch -x -H ldap://10.211.55.4:389 -D "hack@xie.com" -w P@ss1234 -b "DC=xie,DC=com" "(&(samAccountType=805306368)(msds-allowedtodelegateto=*))" | grep -e dn -e msDS-AllowedToDelegateTo
```



```
=xie,DC=com" "(&(samAccountType=805306368)(msds-allowedtodelegateto=*))" |  
grep -e dn -e msDS-AllowedToDelegateTo
```

如图所示，可以看到查询出配置了约束性委派的主机和服务帐户。

```
root@kali:~# ldapsearch -x -H ldap://10.211.55.4:389 -D "hack@xie.com" -w P@ss1234 -b "DC=xie,DC=com" "(&(samAccountType=805306368)(msds-allowedtodelegateto=*))" | grep -e dn -e msDS-AllowedToDelegateTo  
dn: CN=WIN7,CN=Computers,DC=xie,DC=com  
msDS-AllowedToDelegateTo: cifs/AD02.xie.com  
msDS-AllowedToDelegateTo: cifs/AD02  
msDS-AllowedToDelegateTo: cifs/AD02.xie.com/XIE  
msDS-AllowedToDelegateTo: cifs/AD02.xie.com/xie.com  
msDS-AllowedToDelegateTo: cifs/AD02/XIE  
root@kali:~#  
root@kali:~# ldapsearch -x -H ldap://10.211.55.4:389 -D "hack@xie.com" -w P@ss1234 -b "DC=xie,DC=com" "(&(samAccountType=805306368)(msds-allowedtodelegateto=*))" | grep -e dn -e msDS-AllowedToDelegateTo  
dn: CN=service_account,CN=Users,DC=xie,DC=com  
msDS-AllowedToDelegateTo: cifs/AD01.xie.com/xie.com  
msDS-AllowedToDelegateTo: cifs/AD01.xie.com  
msDS-AllowedToDelegateTo: cifs/AD01  
msDS-AllowedToDelegateTo: cifs/AD01.xie.com/XIE  
msDS-AllowedToDelegateTo: cifs/AD01/XIE
```

(3) 查询基于资源的约束性委派

如下命令是查询配置了基于资源的约束性委派的主机和服务帐户。

#查询域中配置基于资源的约束性委派的主机

```
ldapsearch -x -H ldap://10.211.55.4:389 -D "hack@xie.com" -w P@ss1234 -b "DC=xie,DC=com" "(&(samAccountType=805306369)(msDS-AllowedToActOnBehalfOfOtherIdentity=*))" | grep dn
```

#查询域中配置基于资源的约束性委派的服务账户

```
ldapsearch -x -H ldap://10.211.55.4:389 -D "hack@xie.com" -w P@ss1234 -b "DC=xie,DC=com" "(&(samAccountType=805306368)(msDS-AllowedToActOnBehalfOfOtherIdentity=*))" | grep dn
```

如图所示，可以看到查询出配置了基于资源的约束性委派的主机和服务帐户。

```
root@kali:~# ldapsearch -x -H ldap://10.211.55.4:389 -D "hack@xie.com" -w P@ss1234 -b "DC=xie,DC=com" "(&(samAccountType=805306369)(msDS-AllowedToActOnBehalfOfOtherIdentity=*))" | grep dn  
dn: CN=WIN7,CN=Computers,DC=xie,DC=com  
root@kali:~#  
root@kali:~# ldapsearch -x -H ldap://10.211.55.4:389 -D "hack@xie.com" -w P@ss1234 -b "DC=xie,DC=com" "(&(samAccountType=805306368)(msDS-AllowedToActOnBehalfOfOtherIdentity=*))" | grep dn  
dn: CN=krbtgt,CN=Users,DC=xie,DC=com
```

非常感谢您读到现在，由于作者的水平有限，编写时间仓促，文章中难免会出现一些错误或者描述不准确的地方，恳请各位师傅们批评指正。如果你想一起学习AD域安全攻防的话，可以加入下面的知识星球一起学习交流。



谢公子

我加入了这个星球，邀你一起学习



域渗透攻防指南

星主：谢公子

60+	30+	306
成员数量	内容数量	运营天数

书籍  《域渗透攻防指南》官方知识星球。星球讨论与微软AD域相关攻防技术，大家互相交流互相学习，共同进步成长。

现价：¥199

微信扫码加入星球



 知识星球
  谢公子学安全